

Security Governance Transformation Report

TechGlobal Governance Simulation

Prepared by: Lead Security Governance Consultant | Date: 25 September 2026

TechGlobal has experienced rapid organisational growth, expanding to 2,500 employees across five global offices. However, security governance has stagnated, remaining informal and concentrated within the IT Director role. This report provides a comprehensive governance transformation blueprint, addressing structural weaknesses, defining robust cross-functional responsibilities, establishing an executive committee ecosystem, implementing a rigorous RACI matrix, and formulating a material risk escalation and Segregation-of-Duties (SoD) remediation framework.

Task 1 : Governance Architecture & Stakeholder Map

Weakness Analysis of Informal IT-Centric Governance

Weakness Identified	Business & Risk Consequence
1. IT-Centric Decision Concentration	The IT Director acts as security owner, risk approver, and operational chief. This creates bottlenecks, starves security of strategic enterprise alignment, and biases decisions toward operational uptime over risk mitigation.
2. Absence of Formal Committee Structure	Cross-functional security issues (e.g., legal compliance, budget allocation, HR insider risk) lack a dedicated forum, resulting in siloed, uncoordinated local fixes across the five global offices.
3. Limited Board & Executive Visibility	CEO and Board receive sporadic, informal metrics. Material cyber risks are obscured until incidents occur, exposing the organisation to regulatory penalties, brand damage, and executive liability.
4. Inconsistent Business Unit Adoption	Business units operate disparate security practices based on local appetite rather than enterprise standards, creating wide variances in threat exposure across regional branches.

5. Informal Risk Acceptance	Risks are accepted informally by IT management without documented criteria or enterprise risk aggregation, leaving TechGlobal legally and financially unprotected against systemic failures.
-----------------------------	--

Stakeholder Map & Governance Justification

Stakeholder	Authority / Influence	Primary Interest	Information Needed	Governance Contribution
Board	High / Ultimate	Regulatory exposure, brand, material risk, assurance.	Board dashboards, material risk registers, audit findings.	Sets risk appetite, approves strategy, ensures fiduciary oversight.
CEO	High / Executive	Growth, strategic alignment, performance.	Executive summary, strategic KPIs, major incidents.	Drives executive accountability across business units.
CISO	High / Operational	Security strategy, risk oversight, effectiveness.	Threat intel, vulnerability reports, incident metrics.	Leads security programme and operational risk management.
CRO / Risk	Medium-High	Enterprise risk integration, aggregation.	Risk assessments, treatment plans, residual risk logs.	Integrates cyber risk into enterprise risk framework (ERM).
Legal / Comp	Medium	Regulatory duties, privacy, contracts.	Regulatory changes, third-party audits, breach notifications.	Ensures legal compliance and contractual adherence.
Finance	Medium	Budget, loss exposure, investment priority.	Security ROI, budget requests, cyber insurance terms.	Allocates financial resources and financial risk controls.
HR	Medium	Joiner/mover/leaver, awareness, conduct.	Training completion rates, insider threat alerts, vetting.	Governs human capital security and awareness programmes.
IT	Medium-High	Technology delivery, secure operation.	Patch statuses, architecture standards, system uptime.	Implements and operates technical security controls.
BU Leaders	Medium	Operational performance, local risk.	Business unit risk profiles, control requirements.	Owens local operational risk execution and adherence.

Task 2: Governance Responsibility & Authority Matrix

To eliminate ambiguity, core governance roles are structured with explicit decision rights, reporting obligations, and performance indicators (KPIs).

Here is the completed **Appendix B: Governance Responsibility Matrix** for TechGlobal, detailing the purpose, core responsibilities, decision authority, reporting lines, and key performance indicators for all eight core governance roles based on the laboratory specifications:

Role	Purpose	Core Responsibilities	Decision Authority	Reports / Escalates To	KPIs / Evidence
Board	Fiduciary oversight & risk governance	Approve risk appetite, review material risk, ensure assurance.	Ultimate authority on risk appetite, overarching policy, and strategic budget.	Shareholders / External Stakeholders	Zero regulatory fines; timely material risk reporting.
CEO	Executive leadership & strategic alignment	Drive business growth, align security with strategic objectives, oversee executive team.	Executive approval for organization-wide resources, major initiatives, and risk acceptance thresholds.	Board of Directors	Strategic risk alignment; overall business performance against cyber risk tolerance.
CISO	Security governance leadership	Develop security strategy, oversee risk management, manage security policies and programme effectiveness.	Authority over operational security controls, technical standards, and tactical risk mitigation.	CEO and Board (via Risk Committee)	Vulnerability remediation times; security incident frequency; control maturity.
CRO / Risk	Enterprise risk integration	Manage risk methodology, coordinate risk treatment, enterprise risk aggregation.	Authority over risk acceptance thresholds and enterprise risk register maintenance.	CEO and Board Audit/Risk Committee	Comprehensive risk register coverage; alignment with enterprise risk appetite.

Legal / Compliance	Legal and regulatory advice	Ensure regulatory compliance, manage contractual obligations, privacy governance, legal notification support.	Authority on legal notifications, regulatory responses, and contract compliance terms.	CEO and Board	Regulatory compliance adherence; breach notification timeliness.
Finance	Financial governance	Budget management, loss exposure quantification, investment prioritisation, financial controls.	Authority over financial allocations, budget approvals, and financial risk controls.	CEO and Board	Budget variance; ROI on security investments; financial loss mitigation.
HR	People governance	Manage joiner/mover/leaver controls, security awareness training, conduct and disciplinary processes.	Authority over HR security policies, background screening standards, and disciplinary actions.	CEO	Training completion rate; timeliness of offboarding/onboarding security checks.
IT / Technology	Technology delivery	Secure operation of systems, technical implementation, service continuity, infrastructure management.	Authority over IT operational changes, maintenance windows, and technical deployments.	CEO / CIO	System uptime; patch management compliance; incident resolution time.

3.2 Conflict Resolution Note (Overlapping Authority)

Task 3: Security Governance Committee Ecosystem

TechGlobal establishes a three-tier governance committee structure to ensure collective decision-making across strategic, operational, and specialised domains.

Committee Level	Composition & Cadence	Primary Mandate & Decision Scope
-----------------	-----------------------	----------------------------------

Tier 1 : Executive Security Council	CEO (Chair), CISO, CFO, CRO, Legal, IT Director. Cadence: Quarterly	Strategic oversight, major budget approvals, risk appetite alignment, and material incident briefings for the Board.
Tier 2: Security Governance Committee	CISO (Chair), Business Unit Leaders, HR, IT Security Manager, Legal Rep. Cadence: Monthly	Cross-functional policy enforcement, exception management, third-party risk review, and operational remediation tracking.
Tier 3: Specialized Working Group (Cloud & Third-Party)	Cloud Architects, Procurement Lead, Infosec Engineers, Privacy Officer. Cadence: Bi-Weekly	Operational risk reviews for cloud deployments, vendor security assessments, and technical vulnerability triage.

4.2 Sample Committee Decision Log

Date	Decision / Issue	Decision Owner	Decision	Rationale	Actions / Owner	Review Date
12/10/2026	Legacy CRM Security Exception	IT Director	Approved temporary exception with compensating network isolation.	Deploy microsegmentation;	IT Ops	12/01/2027
15/10/2026	Cloud Vendor SOC2 Compliance Gap	CISO	Reject vendor onboarding until ISO 27001 is provided.	Notify vendor;	Procurement	15/11/2026
20/10/2026	Mandatory Phishing Simulation Rollout	HR / CISO	Approved mandatory training for all 2,500 employees.	Launch LMS module;	HR	20/12/2026

Task 4: RACI Accountability Matrix

The RACI matrix defines explicit roles: Responsible (does the work), Accountable (has final approval), Consulted (provides input), Informed (kept updated).

Activity	Board	CEO	CISO	CRO/Risk	Legal	Finance	HR	IT	BU Leader
Cybersecurity strategy approval	A	R	C	C	I	C	I	C	I
Security policy approval	I	A	R	C	C	I	C	C	I
Enterprise cyber-risk	I	I	C	A	I	I	I	R	C

assessment									
Risk acceptance (High/Critical)	I	A	C	R	C	I	I	I	C
Security budget approval	A	R	C	I	I	C	I	C	I
Security architecture approval	I	I	A	I	I	I	I	R	I
Third-party security review	I	I	R	C	C	I	I	C	C
Access governance (IAM)	I	I	C	I	I	I	R	R	C
Incident response governance	I	A	R	C	C	I	C	R	I
Material incident escalation	I	A	R	C	C	I	I	C	I
Regulatory notification decision	I	A	C	C	R	I	I	I	I
Security awareness programme	I	I	C	I	I	I	A	R	C
Vulnerability remediation oversight	I	I	A	C	I	I	I	R	C
Business continuity governance	I	A	C	R	I	C	C	R	C
Board cyber-risk reporting	A	R	R	C	I	I	I	I	I

5.2 RACI Implementation Guide

Managers must consult this RACI matrix prior to launching major initiatives or approving exceptions. Rule of One Accountable: Every activity features strictly one 'A' to prevent divided responsibility. Where disputes arise regarding cross-functional approvals, the Security Governance Committee acts as the arbiter.

Task 5: Cyber-Risk Escalation & Segregation of Duties

Risk Escalation Thresholds

Level	Example Trigger	Decision Authority	Required Notification	Target Response Time
Level 1 – Operational	Standard vulnerability discovered; local firewall block.	IT Operations Manager / Security Lead	24–48 Hours	Level 1 – Operational
Level 2 – Executive	Unpatched zero-day on core platform; high vendor breach.	CISO & CRO (Security Governance Committee)	4 Hours	Level 2 – Executive
Level 3 – Material / Board	Active ransomware, data exfiltration, regulatory breach.	CEO & Board of Directors	Immediate (< 1 Hour)	Level 3 – Material / Board

Segregation-of-Duties (SoD) Weakness Register

ID		Weakness / Conflict	Risk Created	Roles Involved	Recommended Control	Residual Risk / Review
1	IT Director approves own security budget & tools.	Lack of independent financial oversight.	Require CISO sign-off and Finance co-approval.	1	IT Director approves own security budget & tools.	Lack of independent financial oversight.
2	System administrators also perform log auditing.	Undetected malicious log tampering.	Implement automated SIEM with read-only auditor access.	2	System administrators also perform log auditing.	Undetected malicious log tampering.
3	Security team deploys code to production servers.	Bypass of change management controls.	Enforce strict separation between DevOps and Infosec.	3	Security team deploys code to production servers.	Bypass of change management controls.
4	Local BU managers accept critical cyber risks.	Enterprise risk inconsistency across 5 offices.	Centralise risk acceptance with CRO/CEO above threshold.	4	Local BU managers accept critical cyber risks.	Enterprise risk inconsistency across 5 offices.
5	HR lacks independent oversight on insider threats.	Unvetted privileged access provisioning.	Mandate joint HR-Security sign-off for admin accounts.	5	HR lacks independent oversight on insider threats.	Unvetted privileged access provisioning.

Conclusion & Next Steps

By implementing this governance architecture, TechGlobal successfully transitions from informal IT-centric management to a resilient, enterprise-grade security model. Clear accountability, structured committees, and robust risk escalation pathways ensure full Board assurance and regulatory compliance.